

VULNERABILITY ASSESSMENT AND PENETRATION TESTING (VAPT) REPORT

OWASP Broken Web Applications (OWASP BWA)

Document Information

Item	Details
Assessment Type	Vulnerability Assessment & Penetration Testing
Target Host	10.0.2.3
Assessment Platform	Kali Linux
Assessor	Security Analyst
Test Environment	Controlled Lab Environment
Testing Methodology	Black Box / External Assessment
Report Version	1.0

Executive Summary

A Vulnerability Assessment and Penetration Testing (VAPT) engagement was conducted against the OWASP Broken Web Applications (OWASP BWA) virtual machine hosted at IP address **10.0.2.3**. The assessment was performed from a Kali Linux machine located at **10.0.2.4** within an isolated laboratory environment.

The objective of this assessment was to identify security weaknesses, enumerate exposed services, discover web application attack surfaces, validate authentication controls, and evaluate the overall security posture of the target system.

The assessment identified multiple security issues including:

- Weak authentication mechanisms
- Exposure of administrative interfaces
- Legacy and vulnerable software components
- Excessive attack surface through open services
- Critical vulnerabilities detected through automated scanning

Successful authentication was achieved through brute-force testing using default credentials (**admin/admin**), demonstrating inadequate password security controls.

OpenVAS scanning identified vulnerabilities with a maximum severity rating of **Critical (CVSS 10.0)**.

Scope of Assessment

In Scope

Asset	IP Address
OWASP Broken Web Applications	10.0.2.3

Assessment Activities

- Network Discovery
- Service Enumeration
- Port Scanning
- Technology Fingerprinting
- Web Content Enumeration
- Authentication Assessment

- Vulnerability Scanning
- Risk Analysis

Environment Overview

Attacker System

Parameter	Value
Operating System	Kali Linux
Interface	eth0
IP Address	10.0.2.4
Network	10.0.2.0/24

Target System

Parameter	Value
Platform	OWASP BWA
IP Address	10.0.2.3
Network	10.0.2.0/24

Methodology

The assessment followed industry-standard penetration testing practices:

1. Reconnaissance
2. Host Discovery
3. Port Enumeration
4. Service Enumeration
5. Web Application Mapping
6. Authentication Testing
7. Vulnerability Identification
8. Risk Assessment
9. Reporting

Tools utilized during testing included:

- ARP-Scan
- Ping
- Nmap
- WhatWeb
- Gobuster
- Hydra
- DVWA
- OpenVAS

Phase 1 – Host Discovery

ARP Scan

Command

```
arp-scan -l
```

Results

The network discovery process identified three active hosts:

IP Address Description

10.0.2.1 Gateway
10.0.2.3 OWASP BWA Target
10.0.2.4 Kali Linux

Observation

The target system was successfully identified and reachable on the local subnet.

Risk

Low

Phase 2 – Connectivity Verification

ICMP Testing

Kali → Target

Successful communication established between:

10.0.2.4 → 10.0.2.3

Packet Loss: 0%

Target → Kali

Successful communication established between:

10.0.2.3 → 10.0.2.4

Packet Loss: 0%

Observation

Bidirectional communication confirms network accessibility and readiness for assessment activities.

Phase 3 – Network Service Enumeration

Nmap Scan Results

Command

nmap -p- 10.0.2.3

Open Ports Identified

Port	Service
------	---------

22	SSH
----	-----

80	HTTP
----	------

139	NetBIOS
-----	---------

143	IMAP
-----	------

443	HTTPS
-----	-------

445	SMB
-----	-----

5001	Unknown Service
------	-----------------

8080	HTTP Proxy
------	------------

8081	BlackIce Service
------	------------------

Security Impact

Multiple exposed services significantly increase the attack surface available to potential attackers.

Risk Rating

High

Phase 4 – Technology Fingerprinting

WhatWeb Analysis

Detected Technologies

Component Version

Apache 2.2.14

PHP 5.3.2

OpenSSL 0.9.8k

Python 2.6.5

Perl 5.10.1

Security Analysis

Several identified technologies are end-of-life and contain publicly known vulnerabilities.

Risk Rating

Critical

Phase 5 – Web Application Enumeration

Gobuster Enumeration

Directories Identified

Resource Status

phpmyadmin Accessible

wordpress Accessible

joomla Accessible

assets Accessible

images Accessible

javascript Accessible

gallery2 Accessible

test Accessible

cgi-bin Accessible

Security Analysis

The presence of exposed administrative interfaces and development resources increases the likelihood of successful exploitation.

Risk Rating

High

Phase 6 – Authentication Assessment

Hydra Brute Force Testing

Tool

Hydra

Authentication Result

Valid Credentials Discovered:

Username: admin

Password: admin

Observation

The application accepted weak and predictable credentials.

Impact

An attacker can gain unauthorized access to administrative functionality.

Risk Rating

Critical

Phase 7 – DVWA Security Assessment**DVWA Configuration Review****Findings**

Setting	Value
---------	-------

Security Level	Low
----------------	-----

PHPIDS	Disabled
--------	----------

Impact

The environment intentionally exposes vulnerabilities for training purposes, enabling the validation of common attack techniques.

Risk Rating

Informational

Phase 8 – Automated Vulnerability Assessment**OpenVAS Scan Results****Summary**

OpenVAS identified vulnerabilities across multiple severity levels.

Severity Count

Critical	20
----------	----

High	24
------	----

Medium	82
--------	----

Low	5
-----	---

Log	96
-----	----

Maximum CVSS Score

10.0 (Critical)

Security Assessment

The target contains numerous exploitable vulnerabilities capable of leading to:

- Remote Code Execution
 - Authentication Bypass
 - Information Disclosure
 - Privilege Escalation
 - Service Compromise
-

Risk Summary

Vulnerability	Severity
Weak Credentials	Critical
Legacy Software Components	Critical
Multiple Exposed Services	High
Administrative Interface Exposure	High

Vulnerability	Severity
Information Disclosure	Medium
Misconfigurations	Medium

Recommendations

Critical Priority

Enforce Strong Password Policies

- Minimum 12-character passwords
- Password complexity requirements
- Password expiration policies
- Account lockout controls

Remove Default Credentials

- Disable default accounts
- Implement MFA where possible

Patch Legacy Components

Upgrade:

- Apache
 - PHP
 - OpenSSL
 - Python
 - Perl
-

High Priority

Reduce Attack Surface

Disable unnecessary services:

- SMB
- NetBIOS
- Unused Web Services

Restrict Administrative Interfaces

Limit access to:

- phpMyAdmin
- WordPress Administration
- Joomla Administration

Using:

- VPN
 - Access Control Lists
 - Firewall Rules
-

Medium Priority

Security Monitoring

Implement:

- Log Monitoring
- IDS/IPS
- Vulnerability Management Program

Regular Security Testing

Conduct:

- Quarterly Vulnerability Assessments
- Annual Penetration Tests

Conclusion

The assessment successfully identified multiple vulnerabilities within the OWASP BWA environment. The target exhibited weak authentication controls, legacy software versions, exposed administrative resources, and numerous vulnerabilities detected through automated scanning.

The most significant finding was the successful compromise of authentication controls using default credentials (admin/admin), combined with OpenVAS findings indicating Critical severity vulnerabilities with CVSS scores reaching 10.0.

Although OWASP BWA is intentionally vulnerable for training purposes, the findings demonstrate real-world attack paths and highlight the importance of secure configuration management, strong authentication controls, regular patching, and continuous vulnerability assessment.

Overall Risk Rating: CRITICAL